

Guardian — the Sign-Intent Flow

How a natural-language intent becomes a signed on-chain transaction, gated by a deterministic, fail-closed firewall (WYSIWYS).

Dewlock is an **intent-firewall for agentic Sui DeFi**. A single agent (holding **zero user-fund keys**) compiles a stated goal into **one unsigned PTB**; a deterministic **Guardian** re-derives the math and dry-runs that exact bundle; you sign the literal artifact you saw. The diagram below traces that path.

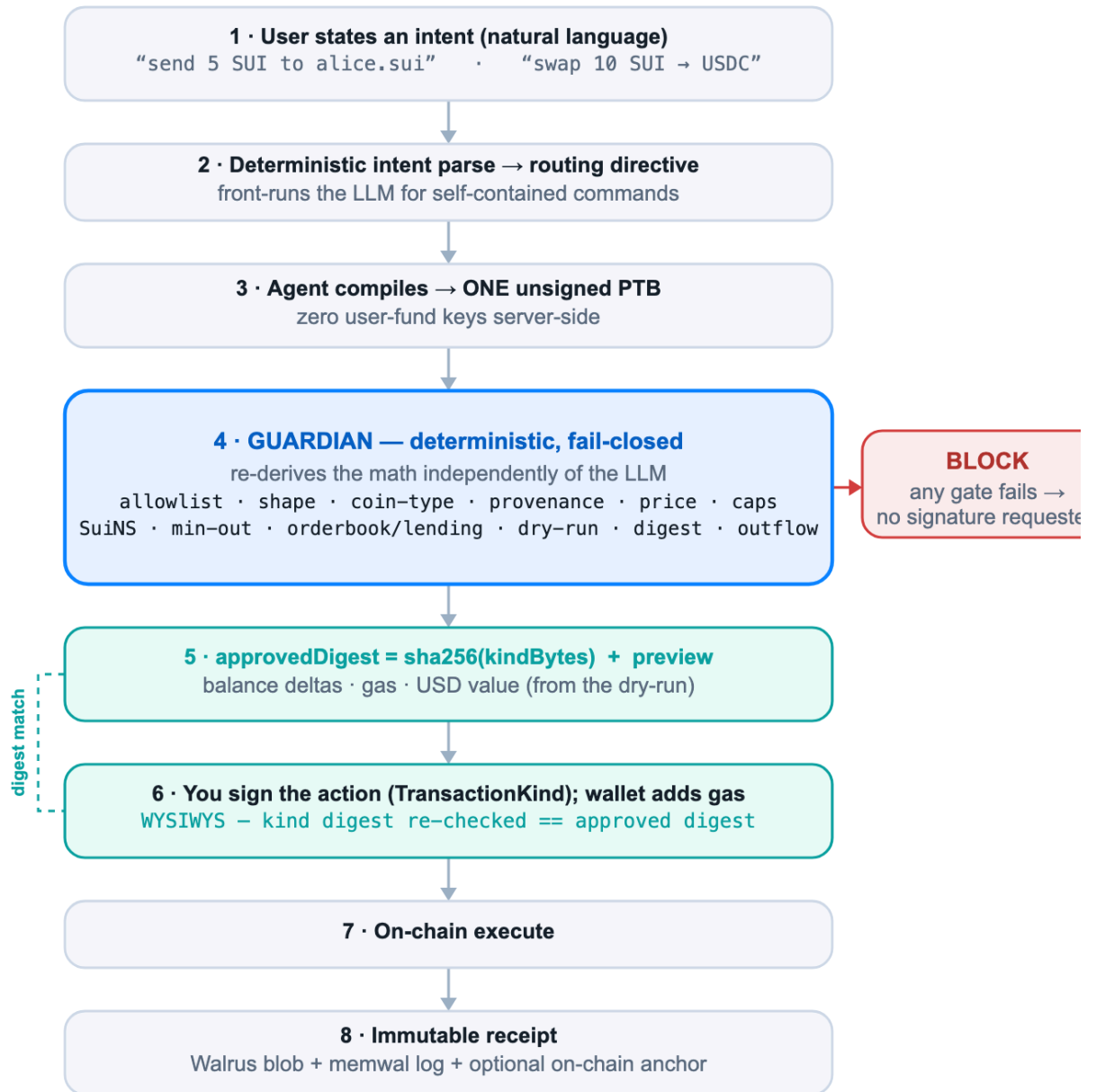


Figure 1 — Sign-intent flow. Any failing Guardian gate blocks before a signature is ever requested.

Guardian gate pipeline (executed in order)

- 1 **Allowlist** — every PTB call `{pkg::mod::fn}` must be pre-approved (runs first).

- 2 **Action-shape** — the MoveCall set must match exactly one `actionType` template $\Rightarrow$ one value action per PTB.
- 3 **Coin-type provenance** — coin types verified on-chain via CoinMetadata (by TYPE, never symbol).
- 4 **Injection provenance** — a `derived` recipient (from inferred / recalled / pool data) forces a confirm gate.
- 5 **Trusted USD price** — real oracle; no price $\Rightarrow$ block (cannot value $\Rightarrow$ cannot verify).
- 6 **Server caps** — per-tx + per-day USD caps; invalid config $\Rightarrow$ block everything.
- 7 **SuiNS lookalike** — homoglyph-normalized edit-distance vs verified contacts.
- 8 **Min-out re-derive** — swaps: recompute min-output from on-chain decimals + the same route source.
- 9 **Orderbook / Lending** — POST_ONLY / self-match / expiry; lending is health-improving only.
- 10 **Dry-run + WYSIWYS digest** — dry-run full bytes for effects (fail-closed); `approvedDigest = sha256(kindBytes)` over the TransactionKind only.
- 11 **Authoritative value gate** — re-value from actual net outflow; block if outflow $> 1.5\times$ declared.

WYSIWYS (What You Sign Is What You Saw). The Guardian dry-runs the full bytes (for effects) but computes `approvedDigest = sha256(kindBytes)` over the **TransactionKind only** — the programmable inputs + commands you previewed, with no gas coin or sender. The wallet reconstructs via `Transaction.fromKind()` and fills a fresh gas coin at sign time; the sign hook re-derives the kind digest from the wallet-built bytes and asserts **`kind digest == approved digest`** before execute. Gas is the wallet's concern; the action is what you consent to. The agent never holds user-fund keys and the LLM never overrides a gate — code is the gate, fail-closed on every dependency.

Source of truth: `packages/agent/src/guardian.ts` · `guardianCheck(proposal, suiClient)` . Diagram rendered to canvas; this document is generated to PDF for hand-off.